

**République du Cameroun**  
**Paix-Travail-Patrie**  
\*\*\*\*

**Ministère de**  
**l'Enseignement Supérieur**  
\*\*\*\*

**Université de Garoua**  
\*\*\*\*

**Faculté des Sciences**  
\*\*\*\*

**Division des Affaires**  
**Académiques, de la**  
**Scolarité et de la**  
**Recherche**

**Republic of Cameroon**  
**Peace-Work-Fatherland**  
\*\*\*\*

**Ministry of Higher Education**  
\*\*\*\*

**Université de Garoua**  
\*\*\*\*

**Faculté of Science**  
\*\*\*\*

**Division of Academic Affairs,**  
**Student's Admission and**  
**Research**



## **UE : ANALYSE FORENSIQUE ET GESTION DES INCIDENTS**

**TPE: LIMITES ET TECHNIQUES D'ÉVASION DES IDS**

| <b>N°</b> | <b>Noms et prénoms</b>  | <b>Matricule</b>       | <b>NIVEAU</b>    |
|-----------|-------------------------|------------------------|------------------|
| <b>1</b>  | <b>NAMAWI JEAN YVES</b> | <b>CM-UGa-24FS0784</b> | <b>MASTER II</b> |

### Exercice 3.1 : Écriture de règle Suricata

Voici une règle Suricata adaptée, avec action, mapping MITRE et SID unique :

```
alert tcp $VLAN20_NET any -> $HOME_NET ![22,80,443] (  
  msg:"VLAN20 Possible Netcat Reverse Shell nc -e /bin/bash";  
  flow:to_server,established;  
  content:"nc"; nocase;  
  content:"-e"; distance:0; within:4;  
  pcre:"/nc\s+-e\s+\/bin\/bash/i";  
  classtype:command-and-control;  
  metadata:attack_target Server, mitre_tactic=Command and Control, mitre_technique=T1059,  
mitre_technique_name=Command and Scripting Interpreter;  
  sid:1004201;  
  rev:1;  
)
```

#### Remarques

- Action : alert.
- Source VLAN : \$VLAN20\_NET pour limiter la détection au VLAN 20.
- Ports ciblés : tout port de destination sauf 22, 80, 443.
- MITRE ATT&CK :
  - T1059 — Command and Scripting Interpreter, car nc -e /bin/bash lance un shell via un interpréteur de commandes.
  - Tu peux aussi ajouter T1105 si tu veux insister sur le transfert ou la session de commande et contrôle, mais la correspondance la plus directe ici est T1059.
- SID : 1004201 est un identifiant unique cohérent pour une règle locale.

Pour une détection plus souple, on peut remplacer le pcre strict par une combinaison de motifs, pour capter aussi des variantes comme nc -c /bin/bash ou ncat --exec /bin/bash :

text

```
alert tcp $VLAN20_NET any -> $HOME_NET ![22,80,443] (  
  msg:"VLAN20 Possible Reverse Shell via Netcat variant";  
  flow:to_server,established;
```

```
content:"nc"; nocase;  
pcr:"/(?nc|ncat){0,20}{?:-e|-c|--exec){0,20}VbinVbash/i";  
classtype:command-and-control;  
metadata:mitre_tactic=Command and Control, mitre_technique=T1059;  
sid:1004202;  
rev:1;  
)
```

#### Conseil de test

Avant mise en production, valide la règle sur des échantillons de trafic et ajuste :

- la variable \$VLAN20\_NET,
- les ports exclus,
- et le niveau de faux positifs.

### **Exercice 4.2 — Analyse d’alerte EVE-JSON**

L’alerte EVE-JSON fournie en TP correspond très probablement à une détection réseau de type scan SYN ou à une autre tentative d’accès suspecte, selon la signature déclenchée dans le champ alert.signature. Le champ alert.action permet ensuite de savoir si le trafic a été autorisé ou bloqué : allowed signifie qu’il n’a été que signalé, tandis que blocked indique un blocage effectif dans une configuration IPS. MITRE ATT&CK peut être utilisé pour rattacher l’événement à une technique précise observée dans l’alerte, en fonction de la signature et du comportement détecté.

#### **(a) Attaque probable**

L’attaque probable est généralement un scan de ports / scan SYN si la signature mentionne une activité de reconnaissance réseau, ou une tentative d’exploitation si la signature nomme un malware, un C2 ou une requête anormale.

Dans une lecture de TP Suricata, le premier réflexe est d’identifier le message de signature, les IP source/destination, le port visé et le type d’action.

#### **(b) TTP MITRE**

Le TTP MITRE dépend de la signature exacte, mais pour un scan réseau la correspondance la plus courante est T1595 — Active Scanning.

Si l’alerte décrit une activité de commande et contrôle, un téléchargement suspect ou une exécution distante, le mapping peut changer, mais l’approche reste la même : relier la signature au comportement observé.

#### **(c) Trafic bloqué ou seulement alerté**

Suricata indique cela dans alert.action :

- allowed = trafic seulement alerté.
- blocked = trafic bloqué en mode IPS avec règle de type drop/reject.

(d) Trois étapes de qualification N1

1. Lire la signature et le contexte réseau : relever signature, src\_ip, dest\_ip, dest\_port, proto et action pour comprendre l'événement.
2. Qualifier la menace : déterminer si l'alerte correspond à une reconnaissance, une tentative d'exploitation, un C2 ou une activité bénigne selon le comportement observé.
3. Vérifier l'impact immédiat : confirmer si le trafic a été autorisé ou bloqué, puis décider de l'escalade N2/N3, de l'ajout à la liste de surveillance ou du déclenchement d'une investigation.

### **Exercice 4.3 — Plan de déploiement IDS.**

**Plan de déploiement IDS/HIDS complet** pour LiZbiZ-SIS, structuré pour couvrir le périmètre réseau, les serveurs critiques et les postes sensibles.

#### **Architecture proposée**

- **NIDS 1 — Périmètre Internet / pare-feu pfSense** : déployé en **tap** ou via **SPAN** en sortie du pare-feu, pour observer le trafic entrant et sortant brut.
- **NIDS 2 — Inter-VLAN / cœur réseau** : placé entre la DMZ, le VLAN applicatif et le VLAN utilisateurs, en **tap** si possible, sinon en **SPAN**, afin de détecter les mouvements latéraux et les flux Est-Ouest.
- **HIDS sur serveurs critiques** : installé sur les serveurs Apache/Nginx, ERP, base de données, contrôleur de domaine et bastion d'administration, pour surveiller les journaux, l'intégrité des fichiers et les événements système.
- **EDR sur postes et serveurs à forte valeur** : déployé sur les machines d'administration, les serveurs exposés et les postes de confiance pour compléter le HIDS avec de la télémétrie comportementale et une capacité de réponse.

#### **Localisation des capteurs**

| Emplacement         | Type | Mode       | Objectif principal                                          |
|---------------------|------|------------|-------------------------------------------------------------|
| Internet ↔ pare-feu | NIDS | Tap / SPAN | Détection des scans, exploitations, C2 entrants et sortants |

|                                      |            |               |                                                                               |
|--------------------------------------|------------|---------------|-------------------------------------------------------------------------------|
| <b>DMZ ↔ VLAN applicatif</b>         | NIDS       | Tap /<br>SPAN | Détection des pivotements et trafics anormaux entre zones                     |
| <b>Serveurs web</b>                  | HIDS       | Agent local   | Surveillance des logs, FIM, exécutions suspectes                              |
| <b>Serveur ERP / base de données</b> | HIDS       | Agent local   | Détection d'accès non autorisés, changements de fichiers, requêtes anormales  |
| <b>Postes admin / SOC</b>            | EDR        | Agent local   | Détection comportementale, isolement, collecte d'artefacts                    |
| <b>Contrôleur de domaine</b>         | HIDS + EDR | Agent local   | Détection d'authentifications anormales, persistance, élévation de privilèges |

### Règles prioritaires

Les règles doivent d'abord couvrir les scénarios les plus probables et les plus impactants : reconnaissance réseau, bruteforce, exécution distante, C2, mouvement latéral et effacement de journaux.

- **Reconnaissance / scan SYN** : alerte sur bursts de ports ou de connexions vers plusieurs hôtes.
- **Bruteforce SSH / RDP / VPN** : seuil par IP et par compte, avec fenêtre glissante.
- **Exécution de scripts suspects** : powershell, bash, python, nc, curl, wget depuis répertoires inhabituels.
- **C2 et beaconing** : connexions périodiques vers IP ou domaines rares, ports non standards, JA3/JA3S atypiques.
- **Mouvement latéral SMB / WinRM / WMI** : corrélation authentification + accès distant inter-serveurs.
- **Effacement ou altération de journaux** : EID 1102, 104, rotation anormale, troncature de fichiers log.
- **Modification de fichiers critiques** : FIM sur /etc, C:\Windows\System32, répertoires applicatifs, clés de registre sensibles.

### Métriques de suivi

Un déploiement IDS n'est utile que si ses performances sont mesurées régulièrement.

Il faut suivre à la fois la qualité de détection et la santé opérationnelle des capteurs.

- **Taux de détection** : part des attaques simulées ou réelles correctement vues par le système.
- **Taux de faux positifs** : nombre d'alertes légitimes mais incorrectes, à réduire en priorité.

- **Taux de faux négatifs** : incidents non détectés, critique pour l'évaluation de couverture.
- **Temps moyen de détection** : délai entre événement réel et alerte SOC.
- **Temps moyen de qualification N1** : délai avant triage et escalade.
- **Couverture MITRE ATT&CK** : pourcentage de techniques pertinentes pour LiZbiZ-SIS réellement détectées.
- **Santé des capteurs** : disponibilité, volume de logs reçus, perte de paquets, latence d'ingestion.
- **Taux d'ingestion normalisée** : pour vérifier que tous les hôtes et segments alimentent bien le SIEM.

### Priorisation de déploiement

1. **Périmètre Internet** avec NIDS en tap/SPAN pour obtenir une visibilité immédiate.
2. **Inter-VLAN** pour détecter les pivotements et les mouvements latéraux.
3. **Serveurs critiques** avec HIDS/FIM.
4. **Postes admin et serveurs exposés** avec EDR.
5. **Tuning des règles et tableaux de bord** sur la base des alertes réelles et des exercices Purple Team.

### Réponse rédigée

Pour LiZbiZ-SIS, le déploiement le plus robuste consiste à placer un NIDS au périmètre Internet, un second NIDS entre les zones réseau internes, puis des HIDS sur les serveurs critiques et un EDR sur les postes d'administration et les hôtes à forte valeur. Les capteurs réseau doivent fonctionner en **tap** quand c'est possible, sinon en **SPAN**, afin de conserver une bonne visibilité sans perturber la production. Les règles prioritaires doivent couvrir les scans, le bruteforce, l'exécution de scripts, le C2, le mouvement latéral et l'effacement de logs, tandis que les métriques de suivi doivent mesurer la détection, les faux positifs, le délai de qualification et la couverture ATT&CK.